FIAP ON

GESTÃO DE RISCO E VULNERABILIDADES

Gestão de RISCO

ABNER NETTO

01

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

LISTA DE FIGURAS

Figura 1.1 – Equação do Risco 7
Figura 1.2 – Princípios do COBIT 5 10
Figura 1.3 – Relacionamentos entre os princípios da gestão de riscos, estrutura e processo 16
Figura 1.4 – Processo de Gestão de Riscos 18
Figura 1.5 – Tratamento do risco 22

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

LISTA DE QUADROS

Quadro 1.1 – Normas ISO série 27000 12
Quadro 1.2 – Exemplo de identificação de riscos 19

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

LISTA DE TABELAS

Tabela 1.1 – Análise de Risco.....20

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

SUMÁRIO

1 GESTÃO DE RISCO 6
1.1 Normas e *frameworks* 8
1.1.1 COBIT 9
1.1.2 ISO 27000 10
1.1.3 ISO 31000 14
1.2 Gerenciamento do Risco 16
1.2.1 Contextualização 17
1.2.2 Identificação 18
1.2.3 Análise do Risco 19
1.2.4 Avaliação do risco 21
1.2.5 Tratamento do risco 21
1.2.6 Aceitação do risco 23
1.2.7 Comunicação e consulta do risco 23
1.2.8 Monitoramento e análise crítica de riscos 24
1.3 Exemplo prático 25
CONCLUSÃO 27
REFERÊNCIAS 28

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

1 GESTÃO DE RISCO

A internet se consolidou como uma ferramenta prática, ágil e alavancadora de negócios, porém com diversas ameaças às operações das empresas, incluindo erros humanos, desastres naturais, espionagem e demais fatores que resultam em perdas financeiras, operacionais ou de imagem da instituição. Com o grande aumento das ameaças cibernéticas nos últimos anos e os prejuízos causados às organizações de diversos segmentos, torna-se imprescindível o gerenciamento da exposição aos riscos por parte de qualquer organização.

A segurança de informações confidenciais para a empresa sempre foi de extrema importância, sejam essas informações armazenadas em papel ou em um banco de dados computacionais, na mão das pessoas erradas podem trazer prejuízos dos mais variados possíveis para as empresas. A estrutura da segurança de informações não pode ser algo estático dentro da empresa e depende da cooperação de todos os envolvidos para seu sucesso. Contudo, muitos gestores têm ignorado os riscos que os seus negócios correm com o vazamento e a perda de informações e, simplesmente, não se preocupam o suficiente com a segurança da informação. (CARUSO; STEFFEN, 1999).

> [...] toda a organização precisa adquirir uma visão sistêmica das suas necessidades de segurança, dos recursos a serem protegidos e das ameaças às quais está sujeita, para então poder identificar as medidas de proteção mais adequadas, economicamente viáveis e capazes de reduzir ou eliminar os principais riscos para o negócio (BEAL, 2005, p. 28).

O risco é a probabilidade de ocorrência de um evento adverso para uma determinada situação esperada. Sêmola (2013) o define como “a probabilidade de que agentes, que são ameaças, explorem vulnerabilidades, expondo os ativos a perdas de confidencialidade, integridade e disponibilidade, e causando impacto nos negócios”. Os impactos são limitados por medidas de segurança, que ajudam a diminuir o risco. Para demonstrar essa relação, o autor propõe a seguinte equação do risco de segurança da informação:

$$\text{RISCO} = \frac{\text{VULNERABILIDADES x AMEAÇAS x IMPACTOS}}{\text{MEDIDAS DE SEGURANÇA}}$$

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Para Hitt et. al. (2005), a gestão do risco é estratégica, pois influencia diretamente as capacidades e competências essenciais da empresa, com maior ênfase aos riscos administrativos e individuais. Os riscos interagem com a realidade e são fatos na vida corporativa, uma vez que resultados incertos são reflexos de decisões gerenciais.

Devido à alta complexidade e ao alto custo de manter os ativos da informação salvos de ameaças à sua confidencialidade, integridade e disponibilidade, é importante adotar um enfoque de gestão baseado nos riscos específicos para o negócio. Sendo assim, a gestão do risco é um conjunto de processos que permite às organizações identificar e implementar as medidas de proteção necessárias para diminuir os riscos a que estão sujeitos os seus ativos de informação, e equilibrá-los com os custos operacionais e financeiros envolvidos (BEAL, 2005).

A figura “Equação do Risco” exibe os componentes do risco e as principais medidas de proteção usadas para reduzi-lo.

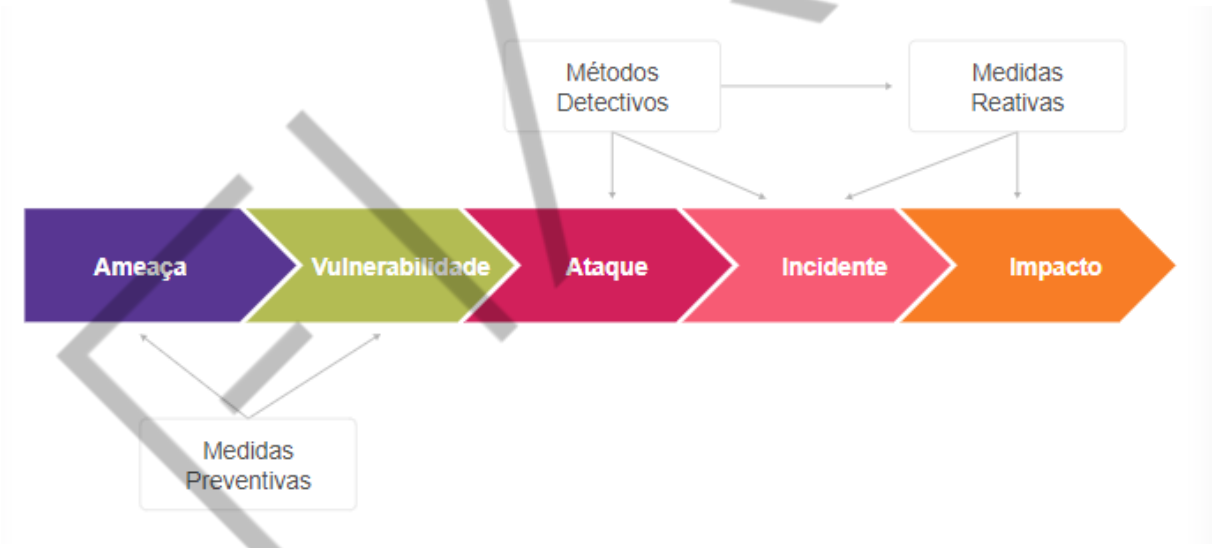

Figura 1.1 – Equação do Risco
Fonte: Beal (2005)

As ameaças somadas às vulnerabilidades, quando mal gerenciadas, facilitam o ataque a um ativo da informação. Um ataque concluído gera o incidente de segurança que culmina em um impacto para os negócios da organização. As seguintes medidas podem ser implementadas para melhor gerenciar o risco:

- **Medidas preventivas:** reduzem a probabilidade de uma ameaça se concretizar ou diminuem o grau de vulnerabilidade do ambiente, ativo ou sistema; reduzindo, assim, a probabilidade de um ataque e/ou sua

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

capacidade de gerar efeitos adversos na organização. São exemplos de medidas preventivas:

- Política de segurança.
- Controles de acesso físicos e lógicos.
- Programas de conscientização e treinamento etc.

- **Métodos detectivos:** expõem ataques ou incidentes e disparam medidas reativas, tentando evitar a concretização do dano, reduzi-lo ou impedir que se repita. São exemplos de métodos detectivos:
  - Monitoração da rede.
  - Sistemas de detecção de intrusos.
  - Auditorias etc.
- **Medidas reativas:** reduzem o impacto de um ataque ou incidente, pois são medidas tomadas durante ou após a ocorrência do evento. São exemplos de medidas reativas, entre outros:
  - Ação legal
  - Restauração do serviço.
  - Procedimentos de resposta a incidentes.

Pela alta capacidade que dados, informação e conhecimento têm de adicionar valor a processos, produtos e serviços, esses constituem recursos cada vez mais críticos para o alcance da missão e dos objetivos organizacionais (CARUSO; STEFFEN, 1999).

1.1 Normas e *frameworks*

“Normas e padrões têm por objetivo definir regras, princípios e critérios, registrar as melhores práticas e prover uniformidade e qualidade a processos, produtos ou serviços, tendo em vista sua eficiência e eficácia.” (BEAL, 2005, p. 36).

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

O que se quer dizer com isso é que não precisamos “reinventar a roda”. Alguma instituição internacional já criou uma norma ou padrão que podemos usar em nossas organizações.

Existem diversas normas e frameworks no mercado para avaliação e tratamento do risco, os principais são: COBIT, ISO27000, ISO27005 e ISO31000.

1.1.1 COBIT

O COBIT é um framework criado e mantido pela *Information Systems Audit and Control Association* (ISACA). Fundada em 1969, uma associação global com 140 mil profissionais em 180 países, suporta e patrocina o desenvolvimento de metodologias e certificações para o desempenho das atividades de auditoria e controle em sistemas de informação, sendo uma delas o COBIT.

O COBIT é direcionado para governança e gestão de Tecnologia da Informação (TI) da organização, ajudando as organizações a criar valor por meio da TI e mantendo o equilíbrio entre a realização de benefícios, a otimização dos níveis de risco e de utilização dos recursos. É baseado em cinco princípios básicos: atender às necessidades das partes interessadas (*stakeholders*); cobrir a empresa de ponta a ponta; aplicar um framework único e integrado; permitir uma abordagem holística; e distinguir a governança da gestão (vide figura “Princípios do COBIT 5”).

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Figura 1.2 – Princípios do COBIT 5
Fonte: Google Imagens, adaptado por FIAP (2020)

O COBIT é importante para gestão de riscos, pois provê boas práticas para o gerenciamento dos processos de TI, interligando os riscos de negócio, assuntos técnicos, necessidades de controle e requisitos de medições de performance. Além de possuir amplas recomendações voltadas à segurança da informação.

Vale ressaltar que a ISACA disponibiliza guias profissionais para uso do COBIT 5, entre eles, um voltado especificamente para a gestão do risco e outro para segurança da informação.

1.1.2 ISO 27000

A fim de implementar e normalizar a atuação das empresas na gestão da segurança da informação, em 1989, o *Commercial Computer Security Center*, órgão ligado ao departamento de indústria e comércio do Reino Unido, publicou a primeira versão do Código para Gerenciamento de Segurança da Informação - PD0003. Seis anos depois, esse código foi revisado e publicado como uma *British Standard*, denominado BS 7799, que apresentava as melhores práticas em controles de

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

segurança para auxiliar as organizações comerciais e de governo na implantação e crescimento da segurança da informação (OLIVA; OLIVEIRA, 2003).

Devido ao interesse internacional em uma norma de segurança da informação, a BS 7799-1:1999 foi submetida à *International Organization for Standardization* (ISO), organização internacional que aglomera os grêmios de padronização/normalização de 148 países. Em dezembro de 2000, a parte 1 BS 7799-1:1999 foi publicada como norma internacional ISO 17799:2000. Em 2001, a Associação Brasileira de Normas Técnicas – ABNT, publicou a versão brasileira da ISO 17799:2000 que ficou com a denominação de NBR/ISO 17799 – Código de Prática para a Gestão da Segurança da Informação. Em setembro de 2005, a norma foi revisada e publicada como NBR ISO/IEC 17799:2005. A partir de 2007, a ISO/IEC 17799 foi incorporada ao novo esquema de numeração como ISO/IEC 27002.

O comitê técnico JTC1/SC27, que trata da segurança da informação na ISO, aprovou a criação de uma família de normas sobre gestão da segurança da informação, batizada pela série 27000. O quadro “Normas ISO série 27000” apresenta algumas normas publicadas desta série:

Título	Objetivo
ISO/IEC 27000:2018 *Information Security Management Systems — Overview and vocabulary*	Apresentar os principais conceitos e modelos relacionados com segurança da informação, incluindo um glossário de termos utilizados na área.
ISO/IEC 27001:2013 *Information Security Management Systems –Requirements*.	Esta norma é aplicável a qualquer organização, independentemente do seu ramo de atuação, e define requisitos para estabelecer, implementar, operar, monitorar, revisar, manter e melhorar um Sistema de Gestão de Segurança da Informação (SGSI). ISO/IEC 27001 é a norma usada para fins de certificação.
ISO/IEC 27002:2018 *Information Technology - Code of practice for information Security Management*.	É um guia prático que estabelece diretrizes e princípios gerais para iniciar, implementar, manter e melhorar a gestão de segurança da informação em uma organização. Os objetivos de controle e os controles definidos nesta norma têm como finalidade atender aos requisitos identificados na análise/avaliação de riscos. É recomendável que seja utilizada com a ISO/IEC 27001.
ISO/IEC 27003:2017 *Information Security Management Systems - Guidance*.	Fornece um guia prático para implementação de um Sistema de Gestão da Segurança da Informação, baseado na ISO/IEC 27001.
ISO/IEC 27004:2016 *Information Security Management - Monitoring,*	Fornece diretrizes com relação a técnicas e procedimentos de medição para avaliar a eficácia dos controles de segurança da informação implementados, dos processos de segurança da informação e do Sistema de Gestão da Segurança da Informação.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

measurement, analysis and evaluation	
ISO/IEC 27005:2018 *Information Security Management Systems - Information Security Risk Management.*	Fornece diretrizes para o gerenciamento de riscos de segurança da informação. Boa parte do escopo da ISO 27005 pode ser interpretada como a sessão 4 da norma ISO 27001, detalhada na perspectiva dos riscos.
ISO/IEC 27006:2015 *Security techniques — Requirements for bodies providing audit and certification of information security management systems*	Define requisitos para organizações que trabalham com auditoria e certificação de sistemas de gestão de segurança da informação.
ISO/IEC 27007:2020 *Information security, cybersecurity and privacy protection — Guidelines for information security management systems auditing*	Aborda diretrizes para guiar a auditoria do sistema de gestão da segurança da informação.

Quadro 1.1 – Normas ISO série 27000
Fonte: Elaborado pelo autor (2020)

Ao longo do conteúdo, o foco será a norma ISO/IEC 27005, específica para gestão de riscos de segurança da informação, mas é importante conhecer um pouco das principais normas da série: 27001 e 27002.

A norma ISO/IEC 27001 define 114 controles de segurança da informação, agrupados em 14 seções e uma seção introdutória sobre análise, avaliação e tratamento de riscos. Sendo:

1. **Política de Segurança da Informação**: recomendações para a formalização de uma política, contendo: diretrizes, princípios e regras que proverão orientação e apoio para implantação e manutenção da segurança.
2. **Organização da Segurança da Informação**: recomendações para o estabelecimento de uma estrutura de gestão para planejar e controlar a implementação da segurança da informação na organização.
3. **Gestão de Ativos**: recomendações sobre a realização de inventário dos ativos informacionais e atribuição de responsabilidades pela manutenção dos controles necessários para protegê-los.
4. **Criptografia**: controles relacionados à gestão de chaves criptográficas.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

5. **Segurança em Recursos Humanos**: recomendações para reduzir os riscos de erro humano, roubo, fraude ou uso indevido das instalações.
6. **Segurança Física e do Ambiente**: recomendações para a proteção dos recursos e instalações de processamento de informações críticas ou sensíveis ao negócio contra acesso não autorizado, dano ou interferência.
7. **Segurança nas Operações**: recomendações para garantir a operação correta e segura dos recursos de processamento de informações e proteger a integridade de serviços e informações.
8. **Segurança nas Comunicações**: controles relacionados à segurança em rede, segregação, serviços de rede, transferência de informação, mensageria etc.
9. **Controle de Acesso**: recomendações para a monitoração e o controle do acesso a recursos computacionais, para protegê-los contra abusos internos e ataques externos.
10. **Aquisição, Desenvolvimento e Manutenção de Sistemas de Informação:** recomendações para o uso de controles de segurança em todas as etapas do ciclo de vida forçam que, com todos os esforços de TI, tudo seja implementado e mantido com a segurança em mente, usando controles de segurança em todas as etapas do processo.
11. **Relacionamento na Cadeia de Suprimentos:** controles sobre o que incluir em acordos e como monitorar os fornecedores.
12. **Gestão de Incidentes da Segurança da Informação**: recomendações para notificação de fragilidades e eventos de segurança da informação, responsabilidades e procedimentos e coleta de evidências.
13. **Gestão da Continuidade do Negócio:** recomendações para preparar a organização para neutralizar as interrupções às atividades comerciais e proteger os processos críticos em caso de ocorrência de falha ou desastre.
14. **Conformidade:** recomendações para a preservação da conformidade com requisitos legais (tais como direitos autorais e direito à privacidade), com normas e diretrizes internas e com os requisitos técnicos de segurança.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Se uma organização desejar obter a certificação em Gestão da Segurança da Informação, deve se adequar às práticas determinadas na ISO 27002 e ser auditada conforme os padrões estabelecidos na ISO 27001.

1.1.3 ISO 31000

A ISO 31000 é a referência à implementação e operacionalização do processo de gestão de riscos em organizações de diversos segmentos de mercado, já que o termo risco nos remete à incerteza, que pode levar a resultados favoráveis ou não ao indivíduo ou à organização.

Segundo essa norma, a gestão de riscos possibilita, a uma organização, o atingimento de diversos objetivos, incluindo:

- Aumento quanto à probabilidade de atingir certos objetivos.
- Encorajamento de gestão proativa.
- Atentar-se à necessidade de identificar e tratar os riscos em toda a organização.
- Melhora quanto ao processo de identificação de oportunidades e respectivas ameaças.
- Atendimento às normas internacionais, requisitos legais e regulatórios pertinentes.
- Melhora quanto ao reporte das informações financeiras.
- Melhora da governança.
- Melhora em relação à confiança das partes interessadas.
- Estabelecimento de uma base confiável para a tomada de decisão e o planejamento.
- Melhora em relação aos controles (incluindo os controles em segurança da informação).
- Alocação e utilização eficaz dos recursos destinados ao tratamento de riscos.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- Melhora da eficácia e a respectiva eficiência operacional.
- Melhora do desempenho quanto à segurança da informação, podendo ainda beneficiar outros aspectos corporativos, como sistemas de qualidade, sistemas de saúde, sistemas ambientais entre outros.
- Melhora quanto à prevenção de perdas e à respectiva gestão de incidentes.
- Minimização de perdas.
- Melhora em relação à aprendizagem organizacional.
- Aumento da resiliência da organização.

Considerando ainda a amplitude desejada quanto ao atendimento de partes interessadas e relação ao processo de gestão de riscos, entende-se que aplicação da regra deve incluir:

- Os responsáveis pelo desenvolvimento da política de gestão de riscos no âmbito de suas organizações.
- Os responsáveis por assegurar que os riscos são eficazmente gerenciados na organização como um todo ou em uma área, atividade ou projeto específicos.
- Os que precisam avaliar a eficácia de uma organização em gerenciar riscos.
- Desenvolvedores de normas, guias, procedimentos e códigos de práticas que, no todo ou em parte, estabelecem como o risco deve ser gerenciado dentro do contexto específico desses documentos.

Em termos processuais (fluxo do processo de gestão de riscos), é possível adotar os seguintes relacionamentos dispostos na figura “Relacionamentos entre os princípios da gestão de riscos, estrutura e processo”, que traz uma relação entre princípios da gestão de riscos, estrutura e processo.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

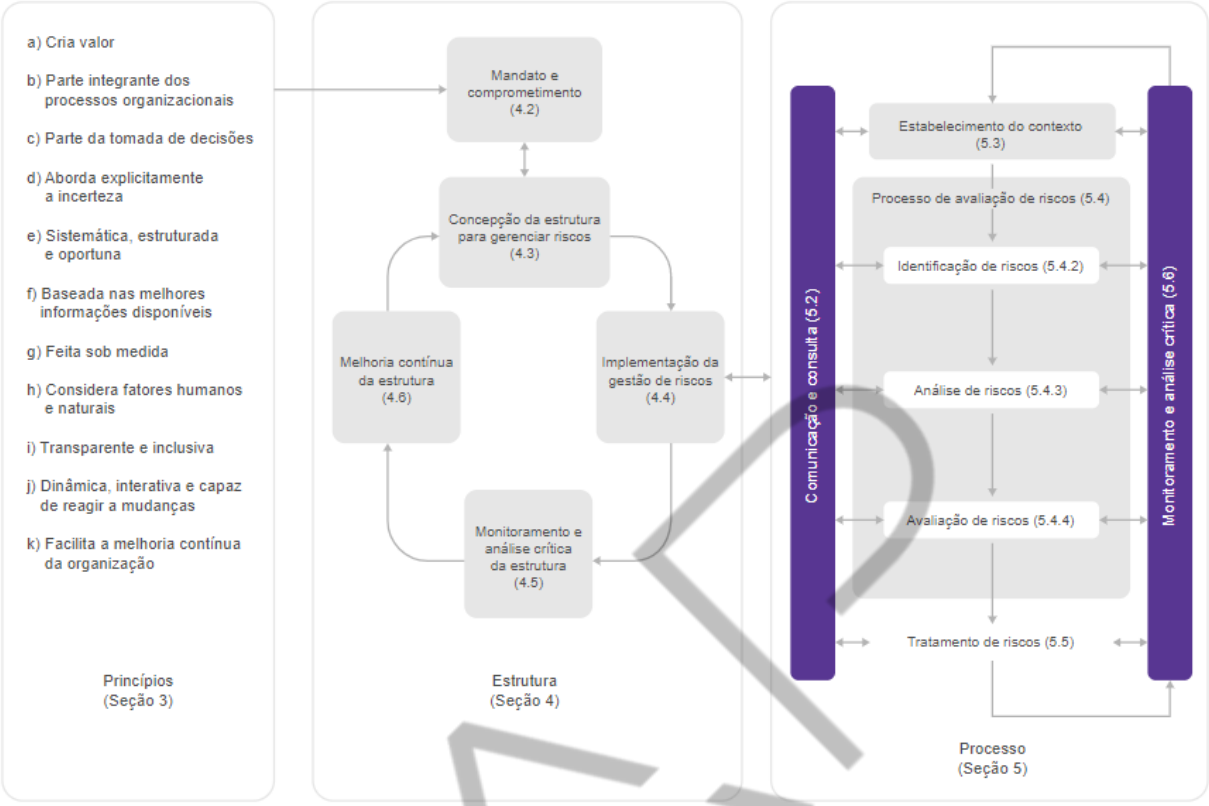

Figura 1.3 – Relacionamentos entre os princípios da gestão de riscos, estrutura e processo
Fonte: ABNT NBR isso/IEC 31000:2009. Gestão de riscos – Princípios e diretrizes (2009)

É possível identificar, na figura, que há menção às seções denominadas princípios, estrutura e processo, divididas respectivamente nas seções 3, 4 e 5, sendo essa a apresentação desses conteúdos na norma ABNT NBR ISO 31000:2009.

1.2 Gerenciamento do Risco

Nas próximas seções, vamos nos aprofundar na ISO/IEC 27005:2011, que trata especificamente sobre riscos de segurança da informação e propõe o fluxo da figura “Processo de Gestão de Riscos” como o processo de gerenciamento do risco.

Inicia-se definindo o contexto, ou seja, o escopo, o objetivo, os métodos a serem considerados, os critérios básicos (avaliação, impacto e tratamento de risco) referentes à gestão a ser realizada. Logo após, é realizada a análise de riscos. Nessa etapa são identificadas as ameaças e os controles existentes para evitar que elas explorem vulnerabilidades. A próxima etapa é a avaliação de riscos, na qual se priorizam os riscos em uma escala do nível mais alto (com impacto financeiro) para o

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

nível mais baixo. Teoricamente, os riscos de maior prioridade devem ser minimizados, passando para a etapa de tratamento do risco.

Alguns riscos não serão tratados, porque as organizações possuem limitações (financeira, de tempo, de cultura, de conhecimento técnico e outros) ou porque não são considerados críticos ou de alto impacto para o negócio. Nesse caso, são aceitos e documentados.

1.2.1 Contextualização

O primeiro passo é definir o contexto, ou seja, os critérios básicos necessários para o gerenciamento, como avaliação, impacto e aceitação do risco; o escopo e os limites da avaliação, bem como a definição dos papéis e responsabilidades das partes envolvidas.

A norma define alguns critérios a serem avaliados, como: valor estratégico e criticidade da informação, requisitos legais e regulatórios, operações comprometidas (internas ou de terceiros), expectativas e percepções dos envolvidos quanto às consequências negativas para o valor da organização, sua imagem e reputação.

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

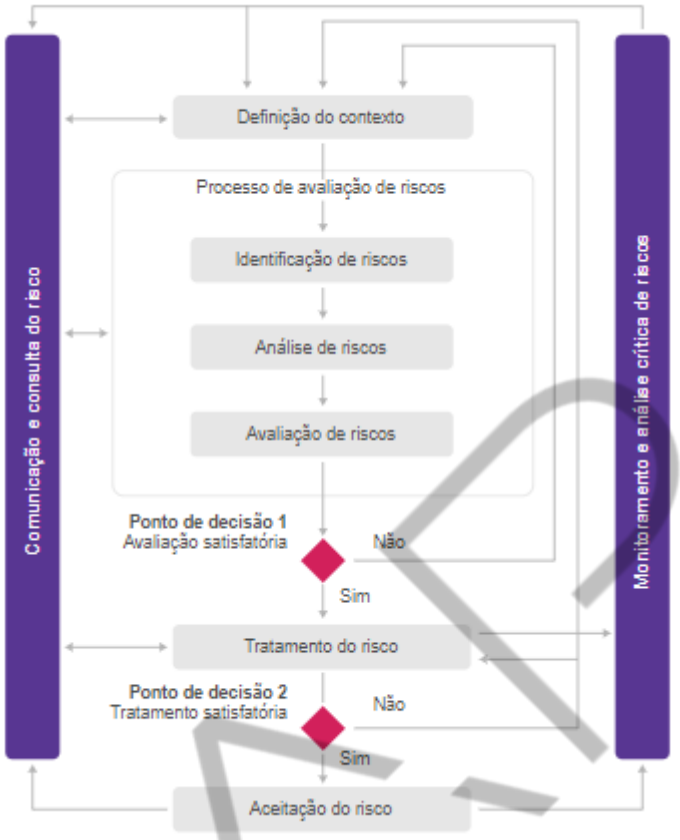

Figura 1.4 – Processo de Gestão de Riscos
Fonte: Google Imagens, adaptado por Fiap (2020)

O escopo define o limite do que será avaliado no processo de gestão de riscos, determinando o ambiente e a relevância para a organização. Pode ser uma aplicação de TI, a infraestrutura de TI, um processo de negócios (vendas, financeiro, controladoria etc.) ou uma parte definida da organização.

Para que o processo de gerenciamento de riscos obtenha sucesso, é importante que todos os envolvidos tenham claros suas responsabilidades e papéis na estrutura, sejam definidas as alçadas para a tomada de decisões e a especificação dos registros a serem mantidos.

1.2.2 Identificação

Uma vez determinado o contexto, devemos identificar os riscos com base nos critérios que foram definidos anteriormente.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- **Identificação dos ativos:** lista de componentes com responsáveis, localidade, função etc. Exemplo: *hardware, software*, redes, aplicações de negócio, instalações físicas.
- **Identificação das ameaças:** informações sobre ameaças obtidas a partir da análise de incidentes, dos responsáveis pelos ativos, de usuários e outras fontes.
- **Identificação dos controles existentes:** documentação de todos os controles existentes e planejados, sua implementação e status de utilização.
- **Identificação das vulnerabilidades:** uma lista de vulnerabilidades associadas aos ativos, ameaças conhecidas e controles existentes.
- **Identificação das consequências:** uma consequência pode ser, por exemplo, uma perda de eficácia, condições adversas de operação, perdas de oportunidades de negócio, reputação afetada, prejuízo etc. Deve-se providenciar uma lista de cenários de incidentes e suas consequências.

A sugestão é criar um quadro para identificação de cada item, conforme o Quadro “Exemplo de identificação de riscos”.

Ativo	Ameaças	Controles Existentes	Vulnerabilidades	Consequências
Sistema Operacional: Windows XP	Sem suporte do fabricante para atualizações de segurança; invasão ou comprometimento por hackers.	Equipamentos com Windows XP não possuem acesso à internet, somente a rede interna.	Falhas conhecidas no software (855 CVE).	Perda de eficácia;prejuízo.

Quadro 1.2 – Exemplo de identificação de riscos
Fonte: Elaborado pelo autor (2020)

1.2.3 Análise do Risco

A análise de riscos pode ser realizada com diferentes níveis de detalhamento e criticidade, dependendo da extensão das vulnerabilidades e dos incidentes anteriores envolvendo a organização. Existem duas metodologias que podem ser utilizadas para análise de riscos: quantitativa e qualitativa. Geralmente, inicia-se com a análise qualitativa para obter uma indicação geral do nível de risco e revelar grandes

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

riscos. Depois, pode ser necessário fazer uma análise quantitativa ou mais específica dos grandes riscos.

- **Metodologia qualitativa:** utiliza uma escala com atributos qualificadores que descrevem a magnitude das consequências potenciais (pequena, média e grande) e a probabilidade de ocorrerem.
- **Metodologia quantitativa:** utiliza uma escala de valores numéricos tanto para consequências quanto para a probabilidade.
- **Avaliação das consequências:** deve-se avaliar o impacto para o negócio com possíveis incidentes que levem à perda da disponibilidade, integridade e confidencialidade do ativo da informação. Considerando o valor de reposição do ativo e o custo da recuperação da informação (se for possível).
- **Avaliação da probabilidade dos incidentes:** considerar a frequência da ocorrência de ameaças e a facilidade com que vulnerabilidades podem ser exploradas.
- **Determinação do nível de risco:** a análise de riscos é baseada nas consequências e na probabilidade estimadas, além disso, ela pode considerar o custo/benefício, as preocupações das partes interessadas e outras variáveis.

Uma tabela ou matriz, como apresentado na tabela “Análise de Risco”, pode ser usada para relacionar as consequências à probabilidade de ocorrência de uma ameaça.

Ameaça	Consequência	Probabilidade	Medida de risco	Ordem da ameaça
Ameaça A	5	2	10	2
Ameaça B	2	4	8	3
Ameaça C	3	5	15	1
Ameaça D	1	3	3	5
Ameaça E	4	1	4	4
Ameaça F	2	4	8	3

Tabela 1.1 – Análise de Risco
Fonte: Elaborado pelo autor (2020)

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

A primeira etapa consiste em avaliar as consequências em uma escala predefinida (1 a 5 por exemplo) para cada ativo ameaçado. Na segunda etapa, estima-se a probabilidade de ocorrência da ameaça. Na terceira etapa, calcula-se a medida do risco multiplicando a consequência pela probabilidade. Por último, ordenam-se as ameaças pela medida do risco.

1.2.4 Avaliação do risco

A avaliação do risco usa a análise do risco, etapa anterior, para a tomada de decisões sobre implementar uma atividade para o tratamento do risco e quais são as prioridades. Devem-se considerar, além dos riscos estimados, os requisitos contratuais, legais e regulatórios.

Para avaliação do risco, consideramos:

- Propriedades da segurança da informação (integridade, disponibilidade e confidencialidade).
- Importância do processo de negócios ou da atividade suportada por um determinado ativo ou conjunto de ativos.

1.2.5 Tratamento do risco

As opções de tratamento do risco devem ser selecionadas com base no resultado do processo de avaliação de riscos, no custo esperado para implementação dessas opções e nos benefícios previstos.

Há quatro opções disponíveis para tratamento do risco, ilustrados na figura “Tratamento do risco”:

- **Modificação do risco:** com a implementação de um controle de segurança da informação, levando em consideração os custos e prazos, além de aspectos técnicos, culturais e ambientais. Os controles podem fornecer os seguintes tipos de proteção: correção, eliminação, prevenção, minimização do impacto, recuperação, monitoramento e/ou conscientização do risco.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- **Retenção do risco:** nesse caso, o risco atende aos critérios para aceitação e não há necessidade de se implementar controles adicionais.

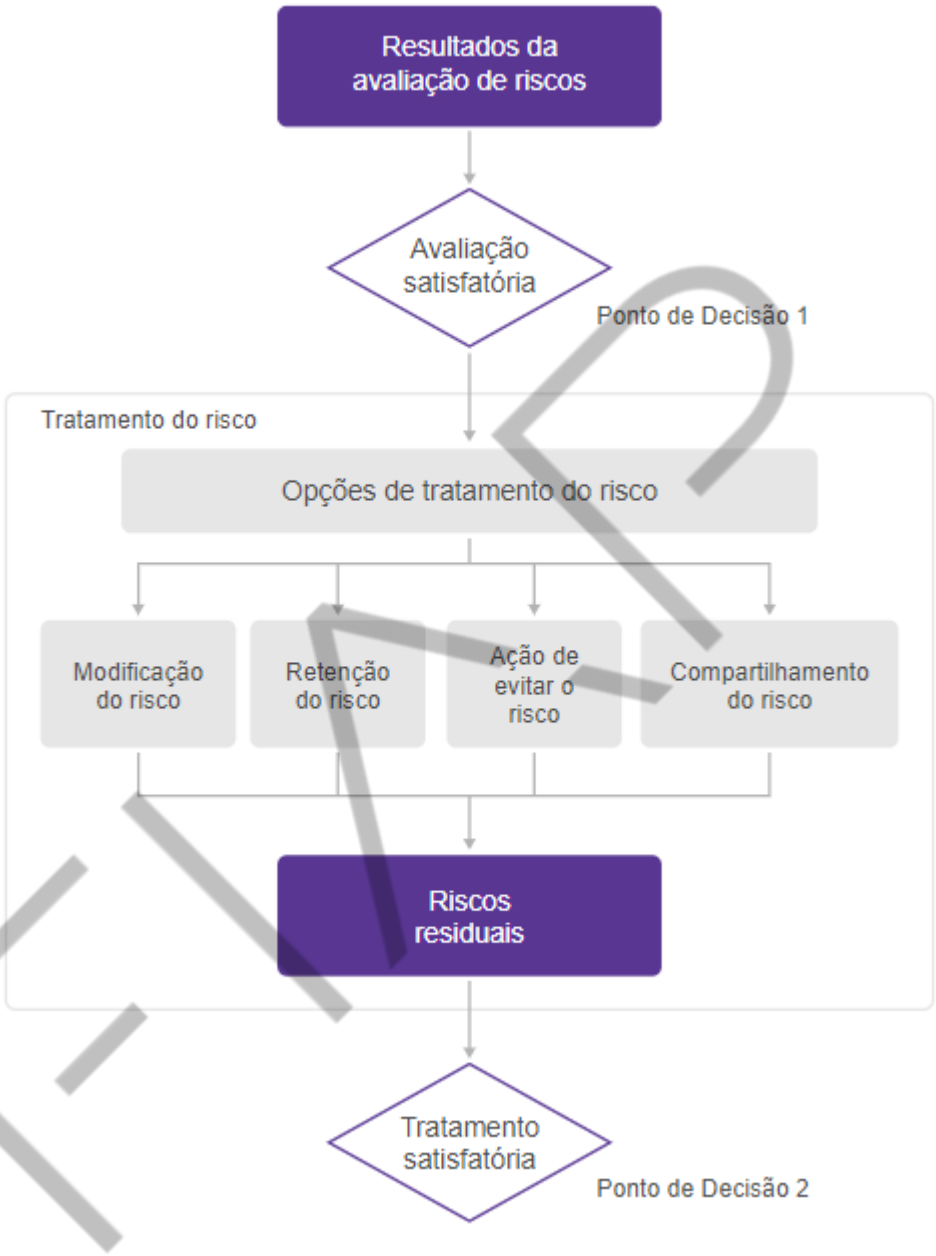

Figura 1.5 – Tratamento do risco
Fonte: Google Imagens, adaptado por Fiap (2020)

- **Ação para evitar o risco:** quando os riscos identificados são considerados demasiadamente altos ou quando os custos da implementação de outras opções de tratamento do risco excederem os benefícios, pode-se decidir que o risco seja evitado completamente. Por exemplo, para um datacenter que tem o risco de inundação constante, pode ser uma alternativa mais rentável mudar fisicamente as instalações.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- **Compartilhamento do risco:** pode ser feito por um seguro que cubra as consequências ou por meio da subcontratação de um parceiro cujo papel seria o de monitorar o sistema e tomar ações imediatas que impeçam um ataque.

1.2.6 Aceitação do risco

O relatório com o plano de tratamento do risco e os riscos residuais deve ser analisado pelos gestores da organização e tomada a decisão de aceitação ou não do risco. A decisão de aceitar o risco (risco residual) deve ser feita e formalmente registrada e com responsabilidade pela decisão e pela justificativa para aqueles que não satisfaçam os critérios normais para aceitação do risco.

Os critérios para aceitação do risco podem ser mais complexos do que somente determinar se o risco residual está ou não abaixo ou acima de um limite definido.

1.2.7 Comunicação e consulta do risco

A comunicação do risco é uma atividade que objetiva alcançar um consenso sobre como os riscos devem ser gerenciados, fazendo uso para tal a troca e/ou partilha das informações sobre o risco entre os tomadores de decisão e as partes interessadas. Conforme Bezerra (2013), deve conter o máximo de detalhes sobre os riscos encontrados, tais como:

- Existência da ameaça, vulnerabilidade e risco.
- Natureza e forma de atuação.
- Estimativa de probabilidade.
- Sua severidade e consequências possíveis.
- Tratamento e aceitação dos riscos.

A comunicação vai permitir o entendimento adequado e a maior agilidade na tomada de decisões para a implementação de mecanismos de controle de riscos, a fim de evitar danos mais significativos. Além disso, permitirá uma melhor percepção

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

dos riscos e dos benefícios do seu rápido tratamento, assim como realizar um trabalho de conscientização sobre a gestão dos riscos e a segurança da informação.

1.2.8 Monitoramento e análise crítica de riscos

O monitoramento pode ser definido como a observação contínua e o registro regular das atividades e ações da gestão de riscos. É um processo rotineiro de coleta de informações da gestão de riscos em todos os seus aspectos. Monitorar é verificar e acompanhar o progresso das atividades da gestão de riscos, ou seja, uma observação sistemática, regular e com o propósito de verificar o desenvolvimento da gestão de riscos (BEZERRA, 2013).

Os riscos e seus fatores (isto é, valores dos ativos, impactos, ameaças, vulnerabilidades, probabilidade de ocorrência) devem ser monitorados e analisados criticamente, a fim de identificar, o mais rapidamente possível, eventuais mudanças no contexto da organização e de manter uma visão geral dos riscos.

Itens a serem monitorados continuamente:

- Novos ativos que tenham sido incluídos no escopo da gestão de riscos.
- Modificações necessárias dos valores dos ativos, por exemplo, devido à mudança nos requisitos de negócio.
- Novas ameaças que podem estar ativas tanto fora quanto dentro da organização e que não tenham sido avaliadas.
- Possibilidade de que vulnerabilidades novas ou ampliadas venham a permitir que alguma ameaça as explore.
- Vulnerabilidades já identificadas, para determinar aquelas que estão se tornando expostas a ameaças novas ou ressurgentes.
- Consequências ou impacto ampliado de ameaças, vulnerabilidades e riscos avaliados em conjunto, em um todo agregado, resultando em um nível inaceitável de risco.
- Incidentes relacionados à segurança da informação.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

1.3 Exemplo prático

Para ilustrar o processo de Gerenciamento do Risco, utilizaremos o case de uma empresa cliente de **Almourol Segurança Cibernética Ltda**, mas que não será devidamente identificada aqui; basta sabermos que ela possui presença nas principais capitais brasileiras e escritórios regionais nas regiões Sul, Sudeste, Centro-Oeste e Nordeste do Brasil. Essa empresa possui um gerente de TI na matriz em São Paulo e responsáveis pelo suporte técnico em cada unidade. Além disso, todas as unidades utilizam VPN (*Virtual Private Network*) para interligação a matriz. A empresa foi infectada pelo vírus **Klez**, e o problema persiste há mais de um mês.

Com base nesse exemplo, vamos efetuar o processo de avaliação/tratamento do risco:

Identificação do risco:

- Infecção por vírus.

Análise do risco:

- O vírus pode levar à perda de dados e indisponibilidade de serviços.

Avaliação do risco:

- Cada unidade da empresa utiliza um antivírus diferente, alguns gratuitos, que não são efetivos no bloqueio do vírus **Klez**.

Depois da realização da análise/avaliação de riscos, a empresa deve optar por tratar ou aceitar o risco. As opções para tratamento do risco são: reduzir, reter, evitar ou transferir o risco.

O gerente de TI e as equipe de suporte locais optaram por mobilizar toda a equipe em um final de semana e limpar todas as estações infectadas. Porém, uma nova infecção aconteceu dias depois, provando que o tratamento do risco não foi efetivo. Sendo assim, outra decisão foi tomada.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Tratamento do risco:

- Substituir o antivírus por uma solução única e gerenciada pela matriz.
- Aplicar *patch* de correções de vulnerabilidades em sistemas operacionais e aplicativos.
- Rever permissões de pastas compartilhadas nos servidores e proibir o uso de compartilhamento em estações de trabalho.
- Palestra de conscientização aos usuários.

Aceitação do risco:

- Existe um risco residual de alguns usuários contrariarem a nova política e serem infectados, porém o risco foi considerado aceitável.

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

CONCLUSÃO

Realizar a devida gestão dos riscos é fundamental para um melhor preparo em eventuais incidentes. Como vimos, com os riscos devidamente identificados, analisados e mensurados, podemos desenvolver previamente planos de ação que, uma vez aplicados, poderão resolver os incidentes de uma forma mais rápida e eficiente.

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

REFERÊNCIAS

ABNT. **NBR ISO/IEC 27005:2011:** Tecnologia da Informação – Técnicas de Segurança – Gestão de Riscos de Segurança da Informação. Rio de Janeiro: ABNT, 2011.

BEAL, A. **Segurança da Informação**: princípios e melhores práticas para a proteção dos ativos de informação nas organizações. São Paulo: Atlas, 2005.

BEZERRA, E. K. **Gestão de Riscos de TI: NBR 27005**. Rio de Janeiro: Escola Superior de Redes, 2013.

CARUSO, C. A. A.; STEFFEN, F. D. **Segurança em Informática e de Informações**. São Paulo: SENAC, 1999.

HITT, M. A.; et. al. **Administração Estratégica**. São Paulo: Pioneira Thomson Learning, 2005.

SÊMOLA, M. **Gestão da Segurança da Informação: uma visão executiva**. 2ª ed. Rio de Janeiro: Campus, 2013.

OLIVA, R. P.; OLIVEIRA, Mírian. Elaboração, Implantação e Manutenção de Política de Segurança por Empresas no Rio Grande do Sul em relação as Recomendações da NBR/ISO 17799. *In*: ENCONTRO NACIONAL DOS PROGRAMAS DE PÓS-GRADUAÇÃO EM ADMINISTRAÇÃO - ENANPAD, 2003, São Paulo. **Anais...** São Paulo: Enapad 2003.

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com